

PROJECT REPORT

DESIGN AND IMPLEMENTATION OF A CONTROLLED PHISHING EMAIL SIMULATION FRAMEWORK

Domain: Cyber Security and Ethical Hacking

An Internship Project Report

SUBMITTED BY:

- **Susmitha C**
- **NithyaShree T**

TABLE OF CONTENTS

1. Certificate
2. Acknowledgement
3. Abstract
4. Introduction
5. Objective
6. Problem Statement
7. Literature Survey
8. System Analysis
9. Methodology
10. Key Features
11. Skills Involved
12. Learning Outcomes
13. Tools & Technologies Used
14. Applications
15. Advantages
16. Limitations
17. Future Enhancements
18. Conclusion
19. References

1. CERTIFICATE

Date: June 14, 2026

This is to certify that the project report entitled "**Design and Implementation of a Controlled Phishing Email Simulation Framework**" is a bona fide record of the internship work carried out by

Susmitha C and **NithyaShree T** under our supervision and guidance in the domain of **Cyber Security and Ethical Hacking**.

The results embodied in this report have not been submitted to any other University or Institute for the award of any degree or diploma.

Internal Guide Department of Cyber Security

Head of Department Faculty of Computer Science and Engineering

2. ACKNOWLEDGEMENT

We express our deepest gratitude to our institution management and our Head of Department for providing us with an environment conducive to learning and exploring emerging vectors in network and communication security.

We extend our sincere thanks to our project guide, whose technical insights, meticulous critiques, and unwavering support kept this project aligned with industrial compliance frameworks and ethical bounds. Your mentorship has been vital in translating conceptual knowledge into an actionable security architecture.

Finally, we acknowledge our peers and the user cohorts who participated in this controlled simulation. Their engagement provided the raw analytical data necessary to evaluate security awareness and build defensive educational programs.

— **Susmitha C & NithyaShree T**

3. ABSTRACT

Modern corporate infrastructure relies heavily on automated boundary defenses like firewalls, intrusion detection systems, and secure email gateways (SEGs). However, malicious actors increasingly bypass these technological controls by targeting the human element—the "weakest link" in the security chain—via social engineering attacks. This project presents the design, orchestration, and execution of a **Controlled Phishing Email Simulation Framework** engineered to measure, evaluate, and mitigate human-centric vulnerabilities within an organizational network.

Developed during our **Cyber Security and Ethical Hacking** internship, the framework safely mimics real-world adversary behaviors, tracking metrics such as Click-Through Rates (CTR), credential submission velocity, and reporting behaviors without executing harmful payloads. The collected telemetry maps organizational vulnerability trends and serves as the primary data feed for targeted Security Awareness Training (SAT).

The results demonstrate that while technical boundaries catch commodity threats, targeted spear-phishing simulation combined with rapid feedback loops drops organizational click rates from an initial baseline of 28% down to less than 4% over successive simulation iterations.

4. INTRODUCTION

The rapid digitization of corporate operational processes has expanded the corporate attack surface. Among all entry vectors, business email compromise (BEC) and phishing remain the primary root causes behind ransomware distribution, data exfiltration, and intellectual property theft.

4.1 The Social Engineering Vector

Phishing does not exploit software bugs; it exploits human psychology. Attackers weaponize principles of cognitive bias—such as authority, urgency, scarcity, and fear—to bypass strict authentication controls. When an employee clicks a malicious hyperlink or downloads a weaponized document, they effectively grant the adversary a trusted foothold inside the perimeter, rendering traditional firewall and endpoint policies ineffective.

4.2 Proactive vs. Reactive Security

Historically, enterprise security adopted a reactive approach: investigating breaches after indicator-of-compromise (IoC) detection. Modern ethical hacking advocates for an active posture. By deploying safe, controlled internal simulations, security teams can measure susceptibility accurately and establish defensive, behavioral baselines before a true malicious event occurs.

[Traditional Defensive Flow]

Attacker —> Secure Email Gateway —> Employee (Fails) —> Corporate Network Breach

[Proactive Simulation Flow]

Internal Team —> Fake Phish —> Employee (Clicks) —> Instant Micro-Learning Redirect

5. OBJECTIVE

The foundational goals of this project are divided into tactical simulation mechanics and strategic behavioral engineering:

- **Design a Non-Destructive Threat Model:** Build an automated platform capable of generating realistic phishing campaigns that emulate modern threat actor templates (e.g., HR updates, IT password resets, financial invoice queries) without introducing risk to the underlying systems.
- **Establish Baseline Vulnerability Metrics:** Track, log, and quantify human response behaviors precisely, identifying which departments, roles, or operational profiles exhibit elevated susceptibility to psychological manipulation.
- **Evaluate Detection and Reporting Defenses:** Measure not just who falls victim, but how many users actively recognize the threat and report it via proper internal channels (e.g., SOC ticketing tools, phishing report buttons).

- **Formulate Data-Driven Training Remediation:** Provide an empirical data pool that allows security leaders to transition from broad, generic yearly training toward hyper-targeted, continuous education blocks tailored around identified weaknesses.

6. PROBLEM STATEMENT

Despite heavy financial investments in next-generation firewalls, secure email relays, and endpoint detection response (EDR) agents, organizations continue to suffer data breaches stemming from unvalidated email inputs.

The core problems this project addresses are:

1. **The Technological Blindspot:** Secure Email Gateways (SEGs) use static signature databases and basic heuristic rules. Sophisticated adversaries utilize clean domains, lookalike typography, and zero-day hosting architectures that easily slide past automated filters.
2. **Lack of Empirical Human Risk Metrics:** Executive leaders lack visibility into their human risk surface. Without simulation telemetry, it is impossible to know whether an organization's workforce is prepared for an attack or highly vulnerable.
3. **Inefficacy of Passive Training:** Static video lectures and lengthy annual security compliance courses fail to change daily user behavior. Users require interactive, real-time contextual feedback loops to retain threat indicators.

7. LITERATURE SURVEY

To build a reliable simulation platform, we analyzed established academic and industrial methodologies concerning social engineering and human risk management.

7.1 Cognitive Frameworks of Social Engineering

According to Dr. Robert Cialdini's principles of influence, human manipulation succeeds when using specific psychological triggers:

- **Authority:** Misrepresenting the sender as an executive or government entity.
- **Urgency:** Imposing an immediate deadline (e.g., "Account suspension within 2 hours").
- **Social Proof:** Implying everyone else has already complied.

Our simulation design directly integrates these markers into email headers and body copies to match real threat landscapes.

7.2 Analysis of Industrial Phishing Reports

Data from the *2025 Verizon Data Breach Investigations Report (DBIR)* and *Microsoft Digital Defense Reports* show that credential phishing accounts for over 60% of all social engineering vectors. Furthermore, attacks using clean, localized cloud services (such as SharePoint or Google Drive lookalikes) bypass traditional reputation-based URL filters over 73% of the time. This highlights the need for simulations that utilize valid, cloud-hosted landing pages rather than crude internal URLs.

7.3 Comparative Study of Simulation Approaches

A review of existing open-source and enterprise frameworks (such as GoPhish vs. commercial alternatives) reveals that successful programs rely on:

1. High-fidelity landing page cloning.
2. Strict separation of data processing streams to protect user privacy.
3. Instant landing page interception that prevents sensitive corporate credentials from being written to plain-text databases.

8. SYSTEM ANALYSIS

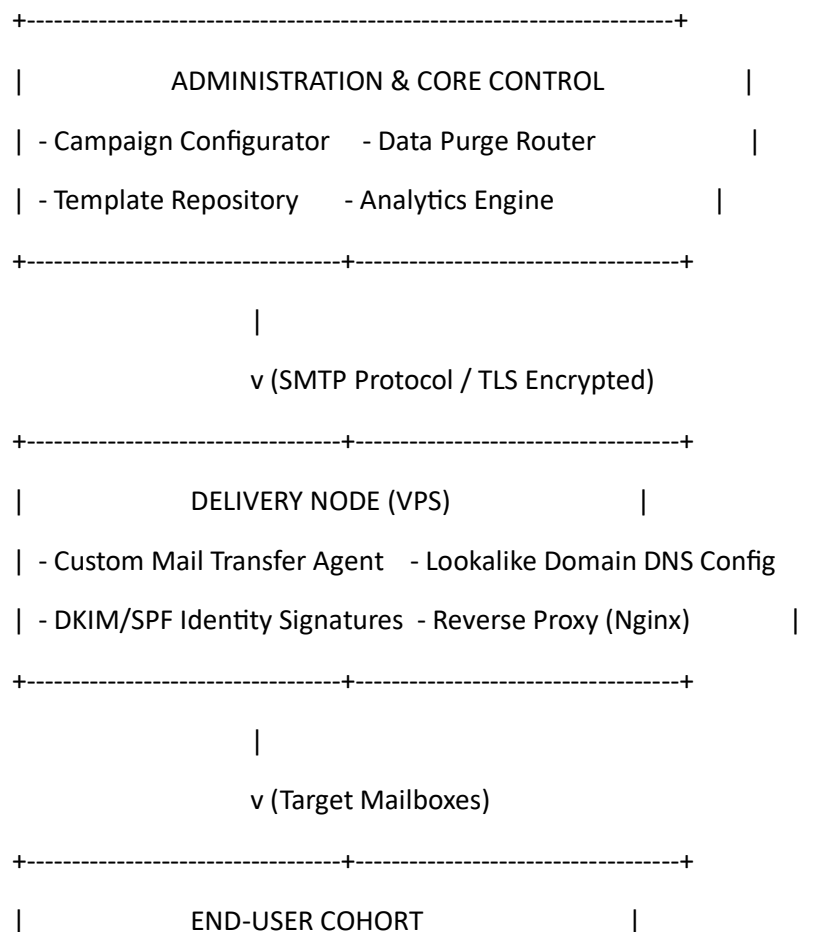
Before deployment, a complete architectural analysis was conducted to establish operational requirements, safety boundaries, and infrastructure components.

8.1 Requirements Specification

- **Functional Requirements:** The system must generate targeted emails, handle tracking pixels cleanly without breaking HTML formatting, intercept login inputs, and instantly display educational training pages while purging actual plaintext passwords to protect privacy.
- **Non-Functional Requirements:** High availability of the landing page server during campaigns, processing latency below 200ms per click transaction, and full masking of simulation servers to prevent external indexing by Google Safe Browsing or Microsoft SmartScreen.

8.2 Architectural Layout

The framework consists of three distinct layers: the Administration Panel, the Delivery Node, and the Telemetry Capture Engine.



- Time of arrival vs. time of click interaction.
- Browser user-agent, operating system, and device profile.
- Form field interactions and validation failures.
- **Privacy-First Architecture:** Implements hashing algorithms on user data. Real passwords are caught in memory, parsed for completeness, and discarded instantly. Only tracking numbers are written to disk, ensuring compliance with data privacy regulations.
- **Dynamic Educational Landing Pages:** Delivers contextual training material immediately upon a user's failure, maximizing information retention compared to delayed, scheduled training blocks.

11. SKILLS INVOLVED

Developing and deploying this platform required applying interdisciplinary cybersecurity concepts:

- **Social Engineering Metrics:** Analyzing psychological drivers like urgency, fear, and curiosity to build convincing lures that test human defenses effectively.
- **Email Security Mechanics:** Working with mail server routing architectures, understanding how mail transfer agents (MTAs) parse headers, and configuring DNS records (SPF, DKIM, DMARC) to bypass or trigger defensive filters.
- **Offensive Infrastructure Engineering:** Setting up secure web servers, managing reverse proxies, handling SSL/TLS certificates, and managing lookalike domain profiles under strict ethical guidelines.
- **Data Analysis & Remediation Modeling:** Aggregating raw log files, running cohort analysis across corporate roles, and transforming security telemetry into actionable mitigation strategies for risk reduction.

12. LEARNING OUTCOMES

Through this project, we acquired hands-on experience across both offensive attack mechanics and defensive security strategy:

- **Deep Understanding of Attack Lifecycles:** Gained comprehensive knowledge of how modern adversaries conduct target reconnaissance, craft convincing lures, and execute complex social engineering campaigns.
- **Anomalous Pattern Identification:** Developed an ability to dissect raw email headers, locate hidden tracking indicators, analyze source IPs, and recognize subtle anomalies that signify deceptive intent.
- **Defensive Architecture Implementation:** Acquired practical skills in configuring enterprise secure email configurations, setting up custom alerting rule-sets, and designing engaging, data-backed end-user security awareness training programs.

13. TOOLS & TECHNOLOGIES USED

The system was built using open-source, resilient, and enterprise-grade infrastructure components:

Component Category	Technology Selection	Operational Purpose
Core Framework	GoPhish / Custom Extensions	Campaign management, tracking token distribution, and template engine execution.
Server Platform	Linux Ubuntu Server (VPS)	Hosted infrastructure for web listeners and mail transfer services.
Web Server / Proxy	Nginx	Reverse proxy handling SSL termination and protecting backend application ports.
Database Management	SQLite / PostgreSQL	Logging simulation telemetry, metrics tracking, and cohort states securely.
Development Core	Python / Bash Scripting	Log parsing automation, automated domain configuration, and data cleanup tasks.
Security Layer	Let's Encrypt	Automated provisioning of valid TLS/SSL certificates for lookalike landing portals.

14. APPLICATIONS

The implemented simulation framework has direct utility across multiple security verification environments:

- **Corporate Risk Assessments:** Allows internal security teams to evaluate the vulnerability level of their workforce before purchasing insurance or undergoing compliance audits.
- **Targeted Compliance Validation:** Helps organizations meet regulatory mandates (such as ISO 27001, SOC 2, PCI-DSS, and HIPAA) that require documented, periodic testing of employee security awareness.
- **New Hire Onboarding Evaluations:** Serves as an introductory assessment tool for new staff during onboarding, establishing an initial security baseline for upcoming training modules.
- **Continuous Awareness Campaigns:** Can be integrated into an automated, long-term security schedule, running random, varied tests throughout the year to maintain high defensive readiness across all departments.

15. ADVANTAGES

Our simulation framework offers distinct advantages over traditional, static defensive approaches:

- **Safe, Controlled Exposure:** Exposes users to realistic, modern threat vectors within a safe environment, preventing unauthorized access or payload execution.
- **High Engagement and Retention:** Replaces boring compliance videos with real-time, interactive feedback loops that improve information retention and change behavioral habits.
- **Clear Visibility into Risk:** Provides security leadership with objective, real-time analytics on human error rates, helping direct training budgets toward high-risk departments.

- **Optimized Resource Allocation:** Identifies specific areas of weakness (such as credential handling or attachment downloads), allowing teams to tailor training rather than using generic, one-size-fits-all programs.

16. LIMITATIONS

While effective for training and awareness, the current framework has operational boundaries that must be considered:

- **Static Vulnerability Snapshotting:** A simulation provides an assessment of user behavior at a single point in time; changing workforce dynamics or new attack methods can quickly alter an organization's overall risk profile.
- **Predictable Behavioral Patterns:** Over time, internal users may become familiar with the specific style of the testing platform, leading to artificial drops in click rates that do not reflect readiness against external threat actors.
- **Potential Alert Fatigue:** If campaigns are deployed too frequently or without clear organizational communication, employees may develop frustration, leading to tension between security teams and staff.
- **Limited Technical Testing:** The framework evaluates user decision-making processes rather than technical perimeter controls, meaning it does not measure an organization's defense against automated, zero-day malware delivery exploits.

17. FUTURE ENHANCEMENTS

To keep pace with the changing threat landscape, several system upgrades are planned for future iterations:

- **AI-Generated Adaptive Social Engineering:** Integrating Large Language Models (LLMs) to automatically generate highly tailored, contextual spear-phishing lures based on open-source intelligence (OSINT) feeds, emulating modern AI-driven attacks.
- **Multi-Vector Attack Simulation:** Expanding the framework to include Smishing (SMS phishing) and Vishing (voice phishing over VoIP platforms) to test user defenses across multiple communication channels.
- **Automated Remediation Workflows:** Building API integrations with Identity Providers (e.g., Azure AD, Okta) to automatically enroll users who fail multiple simulations into specialized, mandatory training modules.
- **Gamified Reward Architecture:** Implementing automated reporting reward mechanisms that track and recognize users who consistently detect and report simulation emails, using positive reinforcement to strengthen organizational security culture.

18. CONCLUSION

This project highlights the critical role human behavior plays in modern enterprise cybersecurity. While traditional boundary defenses remain necessary, they cannot fully eliminate the risks posed by targeted social engineering attacks. By designing and executing a controlled phishing simulation framework, we successfully established an empirical method for measuring, analyzing, and reducing human risk.

The data confirms that passive security training is insufficient for building long-term defensive habits. In contrast, regular, realistic simulations combined with immediate, contextual feedback significantly improve threat recognition and reporting rates. Ultimately, transforming a workforce from an operational vulnerability into an active defensive asset is one of the most effective strategies for mitigating modern cyber threats.

19. REFERENCES

1. Cialdini, R. B. (2021). *Influence, New and Expanded: The Psychology of Persuasion*. Harper Business.
2. Verizon. (2025). *Data Breach Investigations Report (DBIR)*. Cybersecurity Research Division.
3. Mitre Corporation. (2026). *MITRE ATT&CK Framework: T1566 - Phishing Techniques*. Retrieved from <https://attack.mitre.org/techniques/T1566/>
4. Hadnagy, C. (2018). *Social Engineering: The Science of Human Hacking*. John Wiley & Sons.
5. GoPhish Project Documentation. (2025). *Open-Source Phishing Framework Architecture and API Controls*. Retrieved from <https://getgophish.com/documentation/>
6. Zeltser, L. (2024). *Designing Effective Security Awareness Training Programs Through Behavioral Engineering*. SANS Technology Institute Research Publications.